



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:



The background is a solid blue color with a pattern of white binary code (0s and 1s) scattered across it. On the left side, there is a large, stylized padlock icon inside a circle, with several lines radiating outwards, resembling a signal or network. Below this, there is a smaller icon of a shield with a padlock inside, set within a rectangular frame that looks like a computer monitor. On the right side, there is a stylized illustration of industrial infrastructure, including a water tower, pipes, and various tanks or storage units. The overall theme is the security and protection of critical infrastructure.

Legislación sobre Infraestructuras Críticas

Módulo 3

Ley de Protección de Infraestructuras Críticas (LPIC)

Introducción general

- La **Ley 8/2011, de 28 de abril**, establece las bases para la **protección de las infraestructuras críticas (IC)** frente a amenazas deliberadas, como ataques terroristas, sabotaje o ciberataques. Es el marco legal español que **armoniza la seguridad física y lógica** de servicios esenciales para la sociedad.
- Esta ley se enmarca en la estrategia europea de protección de infraestructuras críticas, aunque **tiene su propia estructura y aplicación nacional**, complementando a directivas europeas como **CER (UE 2022/2557)** y **NIS2 (UE 2022/2555)**.

Ley de Protección de Infraestructuras Críticas (LPIC)

¿Qué se considera una infraestructura crítica?

Se define como infraestructura crítica (IC) a toda instalación, red, sistema físico o tecnológico cuya interrupción o destrucción tendría un grave impacto en la seguridad, salud, bienestar económico o funcionamiento del país.

Tipos:

- **Infraestructura Crítica Nacional (ICN):** afecta directamente a España.
- **Infraestructura Crítica Europea (ICE):** su fallo afecta a varios países de la UE.

Ley de Protección de Infraestructuras Críticas (LPIC)

Relación con la Directiva CER (UE 2022/2557)

- La Directiva CER y la LPIC tienen objetivos comunes: proteger **entidades y servicios esenciales**, aunque con enfoques diferentes:

Aspecto	LPIC (España)	CER Directive (UE)
Alcance	Protección física + lógica	Resiliencia ante todo tipo de amenazas
Nivel	Nacional	Europeo (armonizado entre países)
Aplicación	Por sector y operador designado	Por entidad designada por cada Estado
Supervisión	CNPIC (Interior)	Autoridades designadas + Comisión Europea
Compatibilidad	Complementaria	Obligar a adaptar parte de la LPIC

Importante: La transposición de CER en España supondrá una modernización de la LPIC, integrando enfoques más amplios de resiliencia (clima, geopolítica, ciber...).

Ley de Protección de Infraestructuras Críticas (LPIC)

Sectores estratégicos a los que se aplica

- Energía (electricidad, gas, petróleo)
- Transporte (aéreo, ferroviario, marítimo)
- Agua (abastecimiento y saneamiento)
- Salud
- Alimentación
- Sistema financiero
- Administración pública
- Tecnologías de la información y comunicaciones (TIC)
- Industria química
- Nuclear
- Espacio
- Investigación y laboratorios estratégicos

Ley de Protección de Infraestructuras Críticas (LPIC)

¿Cómo se implementa la LPIC?

A. Designación de Operadores Críticos (OC)

- Son las empresas responsables de infraestructuras cuya disrupción afectaría gravemente al país.
- Son designados por resolución del Ministerio del Interior.

B. Planes requeridos:

Documento	Elaborado por	Contenido principal
Plan Estratégico Sectorial (PES)	Autoridad Competente	Análisis y criterios sectoriales
Plan de Seguridad del Operador (PSO)	Operador Crítico	Medidas organizativas, físicas y lógicas
Plan de Protección Específico (PPE)	Operador Crítico	Medidas concretas por infraestructura crítica designada

C. Integración con otras normativas:

ENS, NIS2, Reglamento DORA, ISO/IEC 27001, IEC 62443, etc.

Ley de Protección de Infraestructuras Críticas (LPIC)

Roles fundamentales

Rol	Función
CNPIC (Centro Nacional de Protección de Infraestructuras Críticas)	Coordina, planifica y evalúa los planes de seguridad, y canaliza la relación con operadores críticos.
Autoridades Competentes (por sector)	Identifican IC, validan planes, supervisan su ejecución.
Operadores Críticos (empresas designadas)	Elaboran y ejecutan los PSO y PPE, comunican incidentes y aplican medidas de protección.
Responsable de Seguridad (por parte del OC)	Coordina las medidas de seguridad física, lógica y organizativa.
FFCCSE (Policía, Guardia Civil)	Protegen físicamente las infraestructuras e investigan incidentes.
CCN-CERT / INCIBE-CERT / CSIRT	Apoyo técnico en ciberseguridad, notificación y respuesta a incidentes.

Ley de Protección de Infraestructuras Críticas (LPIC)

Factores de éxito en la implementación

- ✓ Compromiso de la alta dirección del operador
- ✓ Integración entre seguridad física y lógica
- ✓ Actualización y ejercicio periódico de los planes
- ✓ Coordinación fluida con el CNPIC
- ✓ Concienciación y formación del personal
- ✓ Análisis de riesgos realista y actualizado
- ✓ Gestión adecuada de proveedores críticos

Ley de Protección de Infraestructuras Críticas (LPIC)

Consecuencias del incumplimiento

Aunque la LPIC **no impone sanciones económicas automáticas**, el incumplimiento puede conllevar:

- **Suspensión de la designación del operador**
- **Intervención directa por parte del Estado**
- **Revisión del contrato público o concesión**
- **Responsabilidades civiles o penales en caso de incidente**

Además, si el incumplimiento afecta a normativas como NIS2 o ENS, **sí puede haber sanciones económicas relevantes**.

Ley de Protección de Infraestructuras Críticas (LPIC)

Rol del CNPIC y coordinación nacional

El **CNPIC**, dependiente del Ministerio del Interior, es la entidad que:

- Elabora el **Catálogo Nacional de Infraestructuras Estratégicas (CNIE)**
- Designa operadores críticos en coordinación con las autoridades sectoriales
- Revisa y valida los PSO y PPE
- Coordina con CSIRTs, FFCCSE, CNI y otros organismos
- Participa en **foros europeos** sobre protección de infraestructuras

Ley de Protección de Infraestructuras Críticas (LPIC)

Coordinación europea e internacional

- Participación activa en el Critical Entities Resilience Group (CERG)
- Colaboración con ENISA en seguridad digital
- Intercambio de información mediante EU-INTEGRA, CIWIN (Critical Infrastructure Warning Information Network)
- Integración progresiva con las directivas CER y NIS2